GUÍA PRÁCTICA DE LABORATORIO N.º 10

Autenticación JWT entre PharmaMobile y PharmaSoft

Proyecto	PharmaMobile sobre PharmaSoft
Estudiante	Luciana Gutierrez
Tecnologías	Kotlin Multiplatform · Ktor Client · Koin · Compose
Verificación	13 de octubre de 2026
Rama local	feature/auth-jwt-Gutierrez

Resultado general

Se implementó la autenticación JWT completa en la capa compartida, con almacenamiento seguro por plataforma, Bearer automático, recuperación de sesión, permisos, manejo de 401/403 y UI Compose. Oracle y PharmaSoft se levantaron y probaron realmente. Android genera APK y las 39 pruebas pasan; el código iOS compila, pero no se ejecutó por falta de Mac/Xcode.

1. Recursos analizados y alcance

Se revisaron la guía oficial, la colección de pruebas de seguridad, los scripts SQL entregados, el backend oficial actualizado y la estructura actual del proyecto Kotlin Multiplatform. La colección Postman se usó como especificación de escenarios; no se añadió como dependencia de PharmaMobile.

Recurso	Uso en la implementación
Guía Práctica N.º 10	Criterios de JWT, sesión, seguridad, permisos y evidencias.
Colección Postman	Contratos de login, /auth/me, 401, 403, roles y rutas protegidas.
RAR SQL	Comparación de migraciones V2/V3 para usuarios, roles y permisos.
PharmaSoft oficial	Fuente real del contrato y backend ejecutado en puerto 8080.
PharmaMobile	Implementación KMP en commonMain, Android e iOS.

Decisiones de seguridad

• No se incluyó ningún JWT, secreto de firma ni contraseña en el repositorio o en este informe.

• La cabecera Authorization se censura en debug y el registro HTTP se desactiva en release.

• No se inventó una nueva configuración Docker: se reutilizó el contenedor Oracle local existente.

• No se fabricaron evidencias iOS ni capturas del emulador bloqueado.

La rama de trabajo es feature/auth-jwt-Gutierrez. No se realizó push. Los cambios pendientes de la Sesión 08 se conservaron y se mantuvieron fuera del alcance.

2. Oracle y backend PharmaSoft

Se actualizó la copia local de PharmaSoft mediante avance rápido hasta el commit oficial **fff44f9 (seguridad)**. El backend compiló y arrancó con Spring Boot. La base Oracle respondió con el esquema PHARMADB y Flyway aplicó las migraciones de seguridad, dejando el esquema en versión 3.

Elemento	Valor comprobado
Contenedor	pharmasoft-oracle
Imagen	gvenzl/oracle-free:23.26.1-slim-faststart
Puerto	127.0.0.1:1522 → 1521
Servicio	FREEPDB1
Esquema	PHARMADB
Persistencia	Volumen pharmasoft-oracle-data
Backend	Spring Boot en http://localhost:8080

Corrección del SQL entregado

El V2 incluido en el RAR contiene una línea suelta “BD SEGURIDAD”, que no es una sentencia SQL válida. No se copió de forma ciega. La migración oficial de PharmaSoft conserva el modelo requerido y corrige esa línea como comentario; esa fue la versión ejecutada por Flyway.

Pruebas HTTP reales

Escenario	Resultado
GET /api/health sin token	200
GET /api/v1/productos sin token	401
POST /api/v1/auth/login como admin	200 · Bearer · JWT válido · ADMIN
GET /api/v1/auth/me como admin	200
GET /api/v1/productos como admin	200
Login como almacen	200 · ALMACENERO
Clientes como almacen	403

3. Arquitectura implementada

Capa	Componentes	Responsabilidad
Red	HttpClientFactory	JSON, timeout, Auth Bearer y logging seguro.
DTO	LoginDto	Contrato exacto de login y usuario actual.
Mapper	SesionMapper	Convierte DTO a dominio sin filtrar Ktor a UI.
Dominio	Sesion, Credenciales, AuthRepository	Estado y contrato independiente de plataforma.
Datos	AuthRepositorioRest	Login, /auth/me, persistencia y logout.
Seguridad	AlmacenSeguro	Keystore Android y Keychain iOS.
DI	Koin	Cliente, almacenamiento, repositorio y ViewModels.
Presentación	SesionViewModel + Compose	Estados, login, permisos y cierre de sesión.

Flujo de autenticación

1. Compose entrega credenciales validadas al SesionViewModel.
2. AuthRepositorioRest ejecuta POST auth/login sin Bearer previo.
3. El token se guarda en el almacén seguro y se limpia la caché del proveedor.
4. Ktor agrega Bearer automáticamente a las rutas protegidas.
5. Al reiniciar, /auth/me valida el token y reconstruye la sesión.
6. Logout elimina el token y devuelve al login.

Comportamiento por estado HTTP

Estado	Comportamiento móvil
200	La respuesta se mapea a dominio y actualiza la UI.
401	Se elimina el token, se limpia la sesión y se muestra sesión expirada.
403	Se conserva la sesión y se informa falta de permisos.
Timeout/red	Mensaje controlado; no se expone la excepción técnica.

4. Seguridad por plataforma y permisos

Android

• Android Keystore genera una clave AES de 256 bits.

• AES/GCM cifra el JWT antes de persistirlo.

• SharedPreferences conserva únicamente texto cifrado e IV; nunca el token en claro.

• La clave criptográfica no es exportable desde AndroidKeyStore.

iOS

• Keychain Services guarda el JWT como contraseña genérica.

• SecItemCopyMatching recupera el token y SecItemDelete lo elimina.

• El código compila para iosSimulatorArm64 en Windows; la ejecución real requiere macOS/Xcode.

Autorización visible en Compose

Permiso	Efecto en la interfaz
CATALOGO_LEER	Muestra Productos y permite consultar el catálogo.
CATALOGO_ESCRIBIR	Muestra crear, editar y eliminar productos.
CLIENTES_LEER	Muestra Clientes y su acceso rápido.
VENTAS_LEER	Muestra Pedidos y su acceso rápido.

Ocultar controles mejora la experiencia, pero la seguridad efectiva permanece en PharmaSoft. Aunque un cliente manipulado intente llamar una ruta prohibida, el backend responde 403.

5. Verificación y evidencias completadas

La compilación final terminó con BUILD SUCCESSFUL. Se generó el APK Android, se compiló Kotlin para iosSimulatorArm64 y pasaron las 39 pruebas Android host, con cero fallos, errores u omitidas.

En Android se ejecutaron realmente login ADMIN, recuperación de sesión tras reiniciar el proceso, logout, error por credenciales inválidas y acceso ALMACENERO. Logcat confirmó Authorization: *** y HTTP 200 para productos y /auth/me.

En Postman se ejecutó la colección de seguridad contra el backend local. Las capturas muestran health 200, credenciales inválidas 401, ausencia de token 401 y login de ambos roles con sus cuatro pruebas aprobadas.

Las páginas siguientes incluyen las capturas originales y una descripción de lo que comprueba cada una. Los JWT y las contraseñas válidas no se incluyen en las imágenes del informe.

Se verificó el CRUD completo desde Android con EvidenciaJWT_S10: creación 201, lectura 200, actualización 200 y eliminación lógica 204. El producto queda inactivo en Oracle; los productos anteriores se preservan.

Los tres usuarios oficiales autenticaron correctamente. VENDEDOR ve el catálogo sin escritura; ALMACENERO no ve Clientes ni Pedidos. Se capturó Authorization: *** en Android Studio.

Se provocaron 403 y 401 reales mediante cambios temporales de la cuenta local almacen, restaurados en finally. Ante 403 se conserva sesión; ante 401 se borra jwt_cifrado y se regresa al login. No se creó Prueba403_S10.

Las pruebas y capturas iOS se omiten por solicitud expresa y falta de macOS/Xcode. No se afirma ejecución multiplataforma completa. Se conserva el código iOS de la implementación.

Git: feature/auth-jwt-Gutierrez. Commits publicados: 1fc3834 (implementación) y 8ed2928 (evidencias iniciales). No se fabricó historial. Las nuevas evidencias corresponden a la verificación posterior.

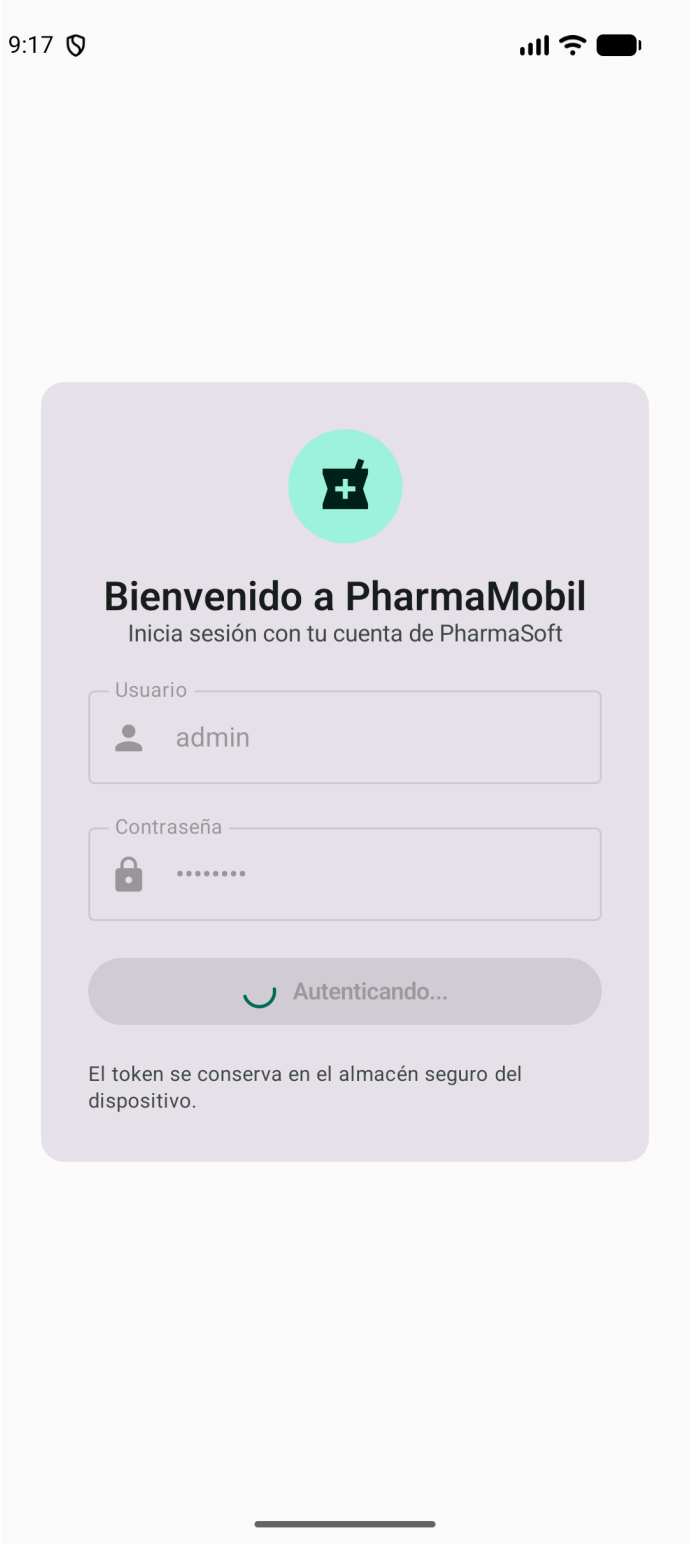
6. Comprobación de los diez criterios

N.	Criterio real de la guía	Resultado y evidencia
1	Login obtiene JWT real	CUMPLE. ADMIN, VENDEDOR y ALMACENERO, HTTP 200.
2	Almacenamiento seguro	CUMPLE EN ANDROID. Keystore AES/GCM; recuperación después del reinicio.
3	Auth adjunta Authorization automáticamente	CUMPLE. Prueba MockEngine y CRUD real protegido.
4	sendWithoutRequest en rutas protegidas	CUMPLE. Envío anticipado de Bearer; login excluido.
5	Logging saneado	CUMPLE. Captura Android Studio con Authorization: ***.
6	Persistencia al cerrar y reabrir	CUMPLE. Proceso detenido; /auth/me 200 y sesión recuperada.
7	401 borra token y vuelve al login	CUMPLE. Cuenta revocada temporalmente; token local ausente y mensaje.
8	403 mantiene sesión y muestra mensaje	CUMPLE. POST denegado; mensaje y permanencia en Productos.
9	UI según permisos	CUMPLE. VENDEDOR sin escritura; ALMACENERO sin Clientes/Pedidos.
10	Funcionamiento multiplataforma	IOS OMITIDO POR SOLICITUD. Android ejecutado; iOS no probado.

Entregables: rama con commits reales; login de tres usuarios; CRUD Android autenticado; Logcat saneado; 403 deliberado con mensaje; README Autenticación actualizado. iOS se omite en esta entrega. No se afirma haber distribuido commits de implementación en fases que no se registraron originalmente.

Evidencia 01. Estado de autenticación

Compose muestra Autenticando y deshabilita los campos y el botón mientras espera la respuesta. La contraseña permanece oculta.



Fuente: captura real de Android o Postman. Archivo: 03_admin.png

Evidencia 02. Login ADMIN exitoso

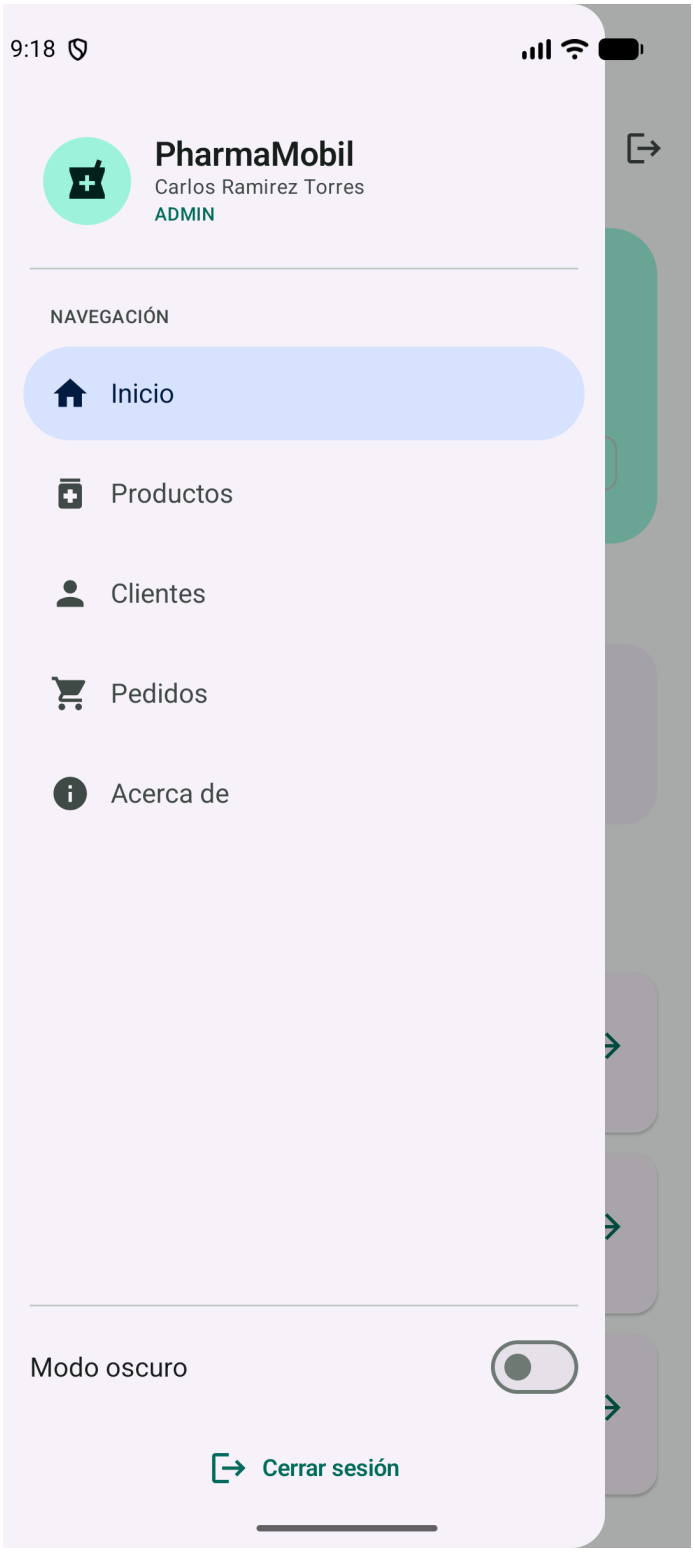
Después de autenticar contra PharmaSoft, la aplicación accede a Inicio y muestra sus accesos rápidos. La respuesta de login fue HTTP 200.



Fuente: captura real de Android o Postman. Archivo: 04_resultado_login.png

Evidencia 03. Navegación del administrador

La cabecera identifica al usuario de prueba y al rol ADMIN. Productos, Clientes y Pedidos están disponibles conforme a los permisos del backend.



Fuente: captura real de Android o Postman. Archivo: 05_menu_admin.png

Evidencia 04. Recuperación después del reinicio

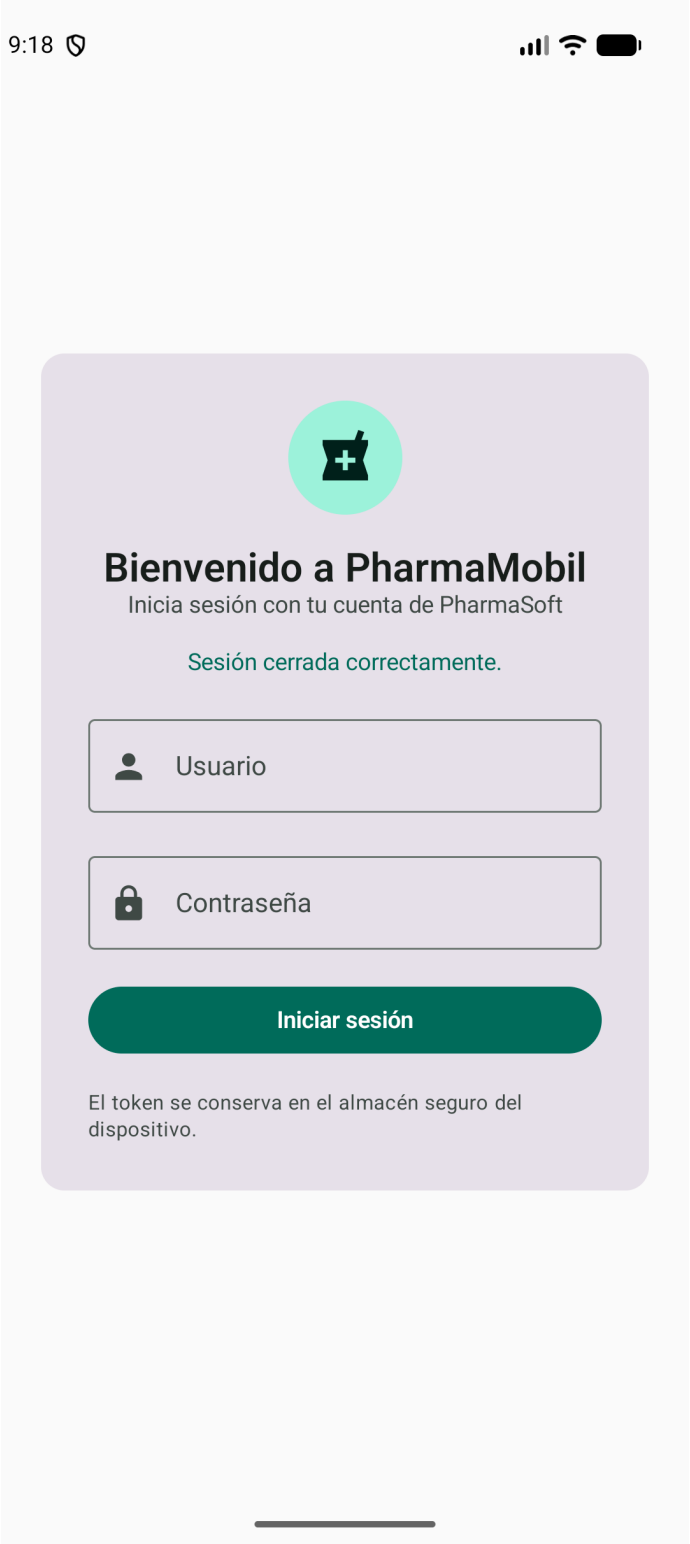
Se detuvo el proceso Android y se abrió nuevamente la aplicación. Se recuperó el token guardado, /auth/me respondió HTTP 200 y apareció Inicio sin volver a ingresar credenciales.



Fuente: captura real de Android o Postman. Archivo: 06_sesion_recuperada.png

Evidencia 05. Cierre de sesión

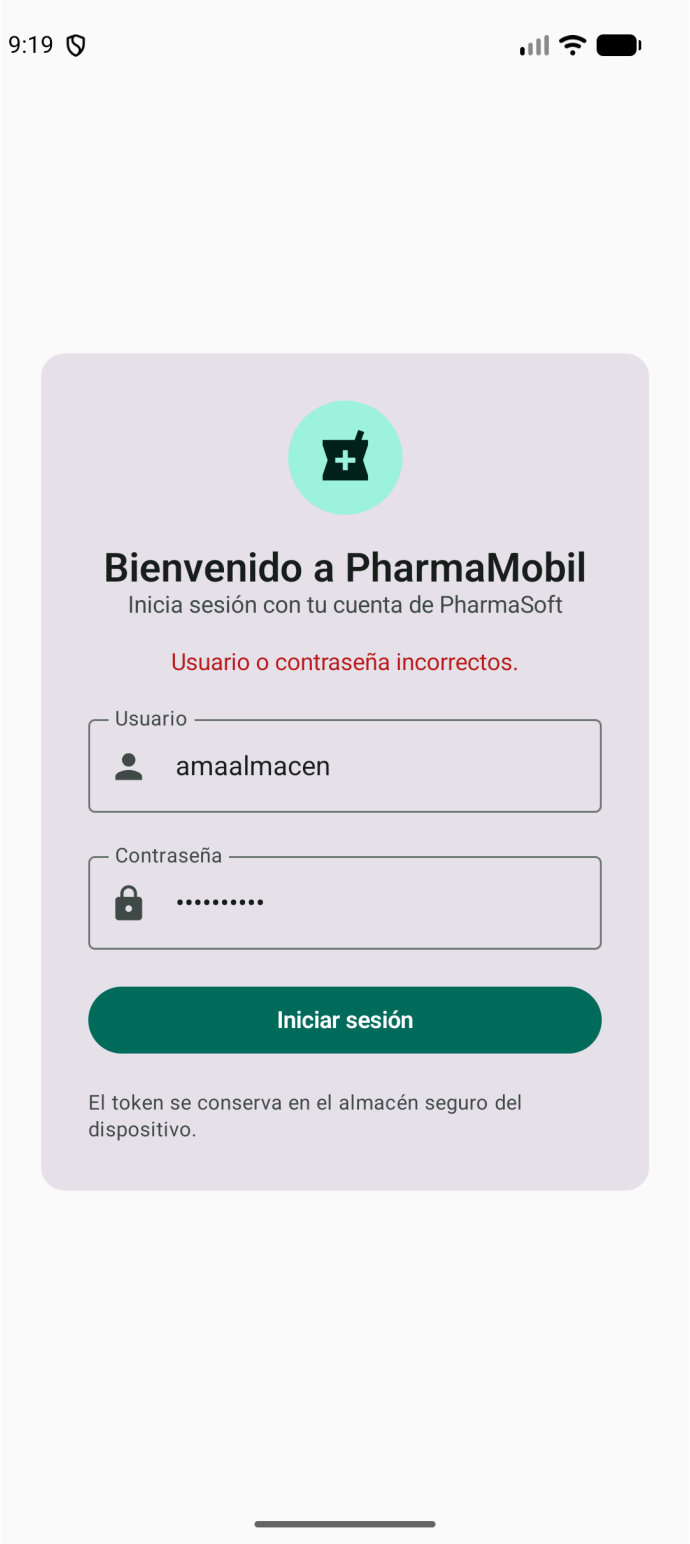
Al pulsar Cerrar sesión se volvió al login y apareció Sesión cerrada correctamente. El repositorio elimina el token y limpia la caché Bearer.



Fuente: captura real de Android o Postman. Archivo: 07_logout.png

Evidencia 06. Rechazo de credenciales incorrectas

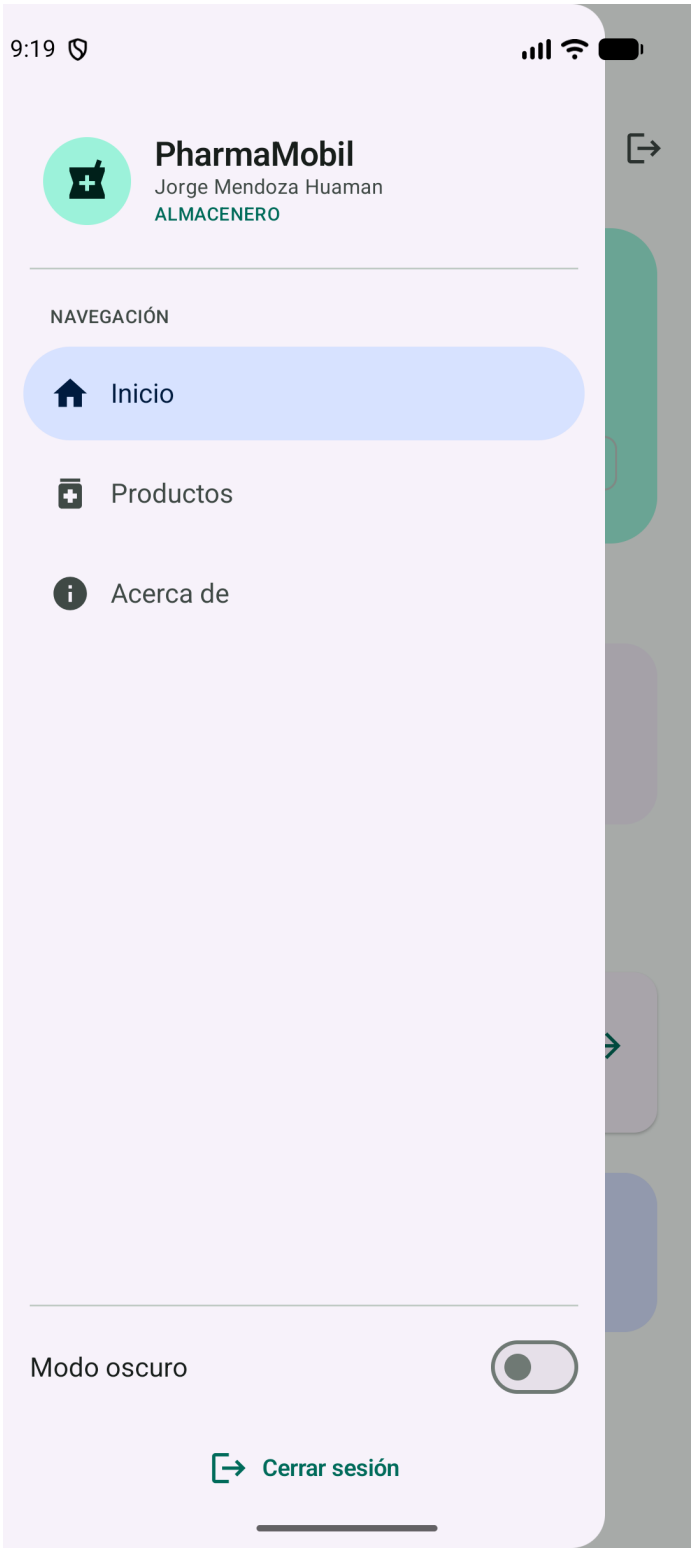
Una solicitud con usuario inválido recibió HTTP 401. La interfaz mostró Usuario o contraseña incorrectos y permitió corregir los campos.



Fuente: captura real de Android o Postman. Archivo: 08_almacen.png

Evidencia 07. Menú restringido de ALMACENERO

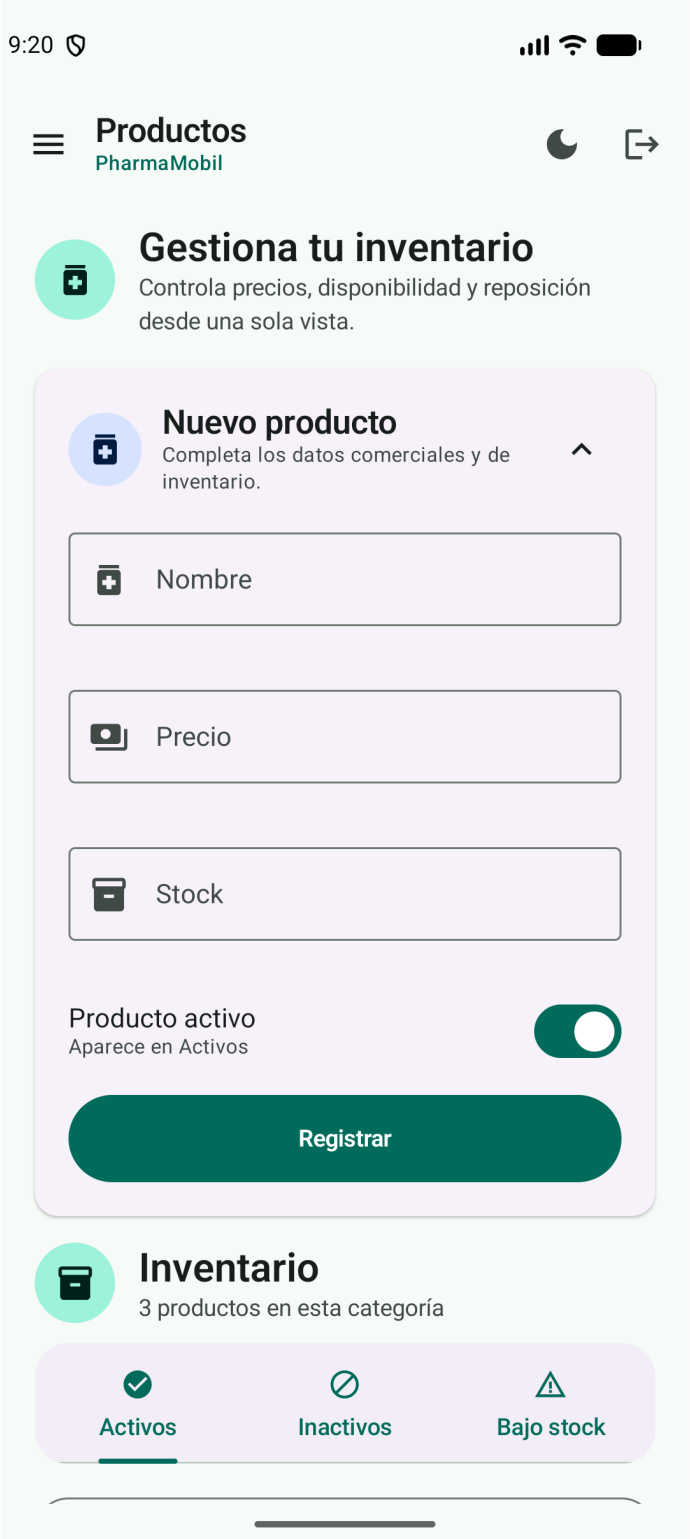
El rol ALMACENERO dispone de Productos y Acerca de. Clientes y Pedidos no aparecen, porque la sesión carece de esos permisos.



Fuente: captura real de Android o Postman. Archivo: 10_menu_almacen.png

Evidencia 08. Catálogo protegido y permiso de escritura

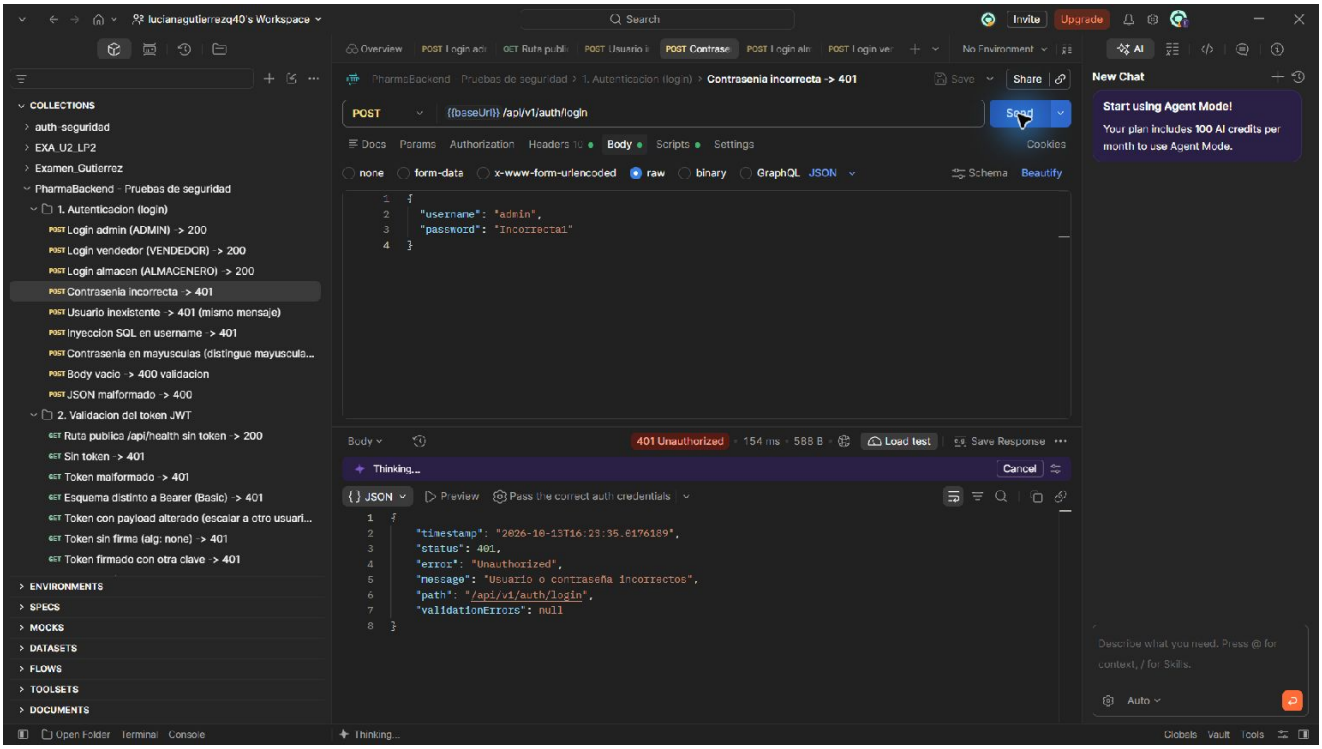
La pantalla Productos muestra tres productos remotos. Nuevo producto está habilitado porque ALMACENERO posee CATALOGO_ESCRIBIR. Las consultas protegidas usan Bearer automáticamente.



Fuente: captura real de Android o Postman. Archivo: 11_productos_bearer.png

Evidencia 09. Postman: contraseña incorrecta

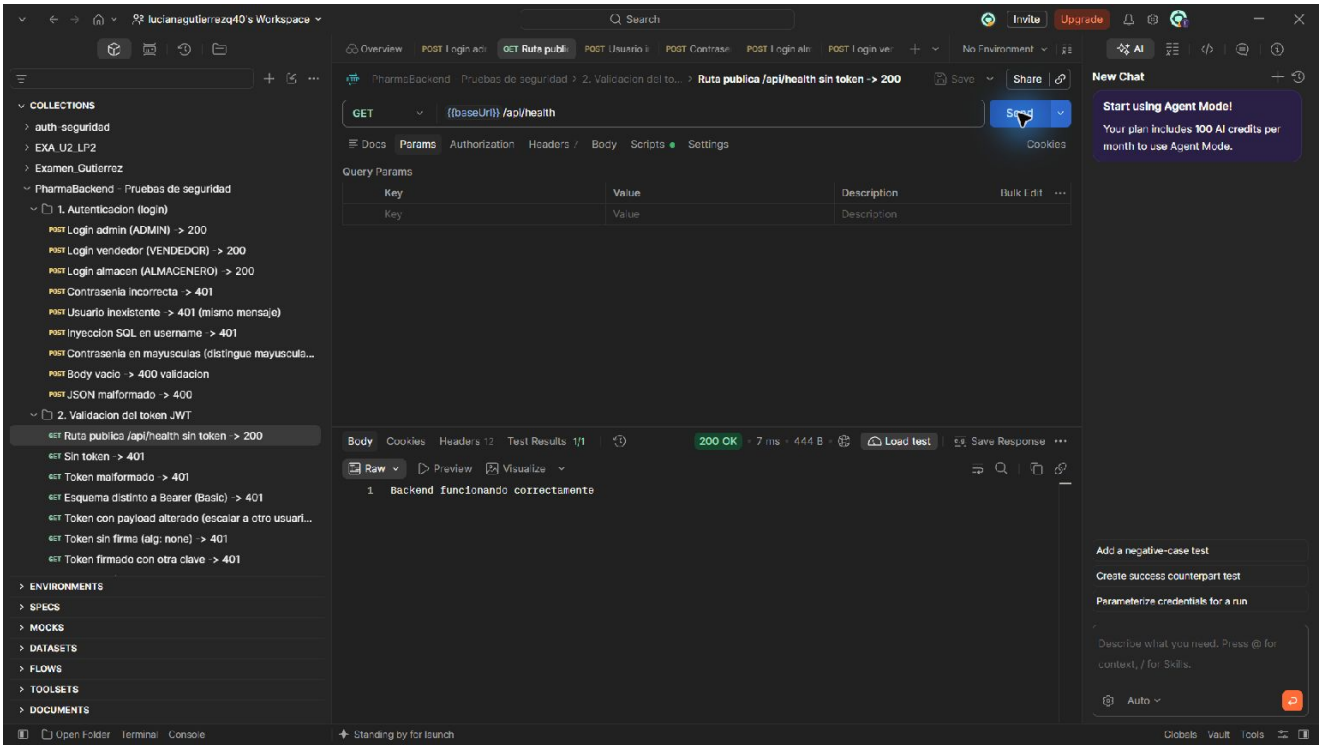
POST /api/v1/auth/login devuelve 401 Unauthorized y el mensaje Usuario o contraseña incorrectos. Es una respuesta real del backend local.



Fuente: captura real de Android o Postman. Archivo: 12_postman_login_401.jpg

Evidencia 10. Postman: backend disponible

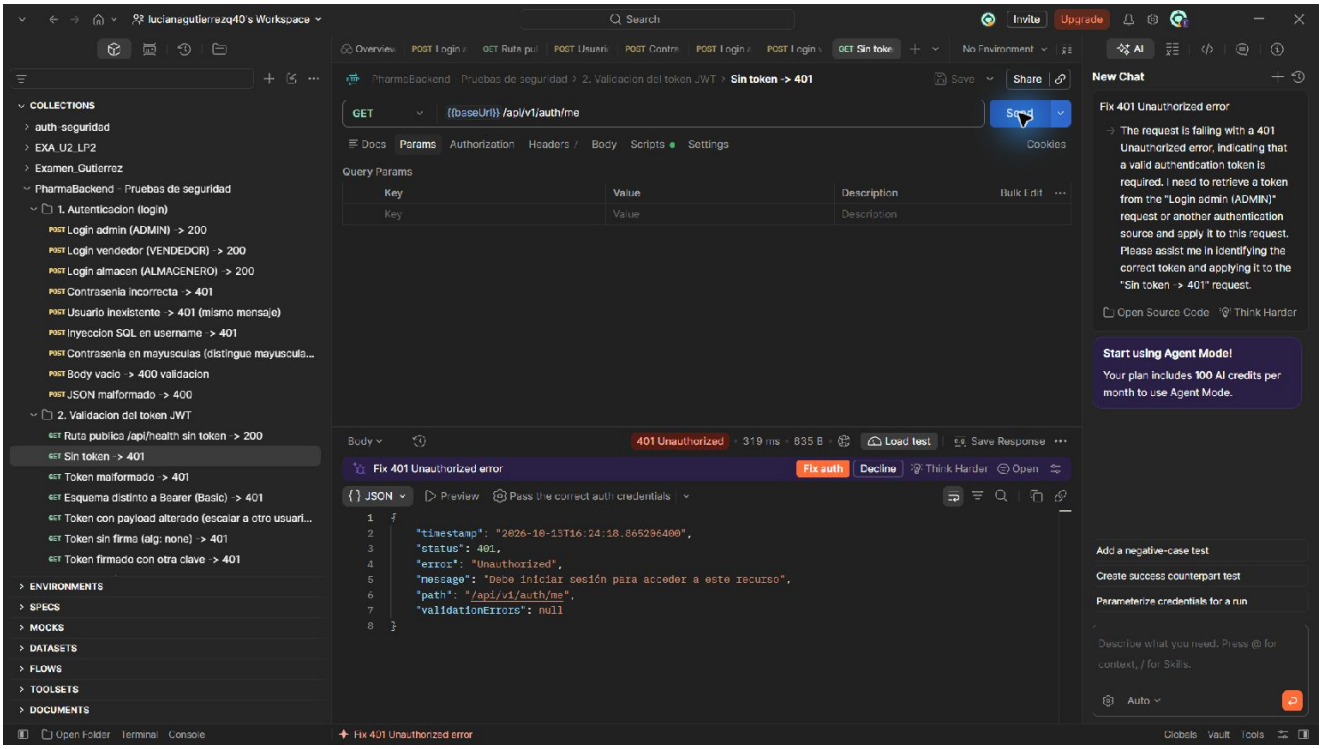
GET /api/health sin token devuelve 200 OK y Backend funcionando correctamente. La prueba de la colección también aparece aprobada.



Fuente: captura real de Android o Postman. Archivo: 13_postman_health_200.jpg

Evidencia 11. Postman: recurso protegido sin token

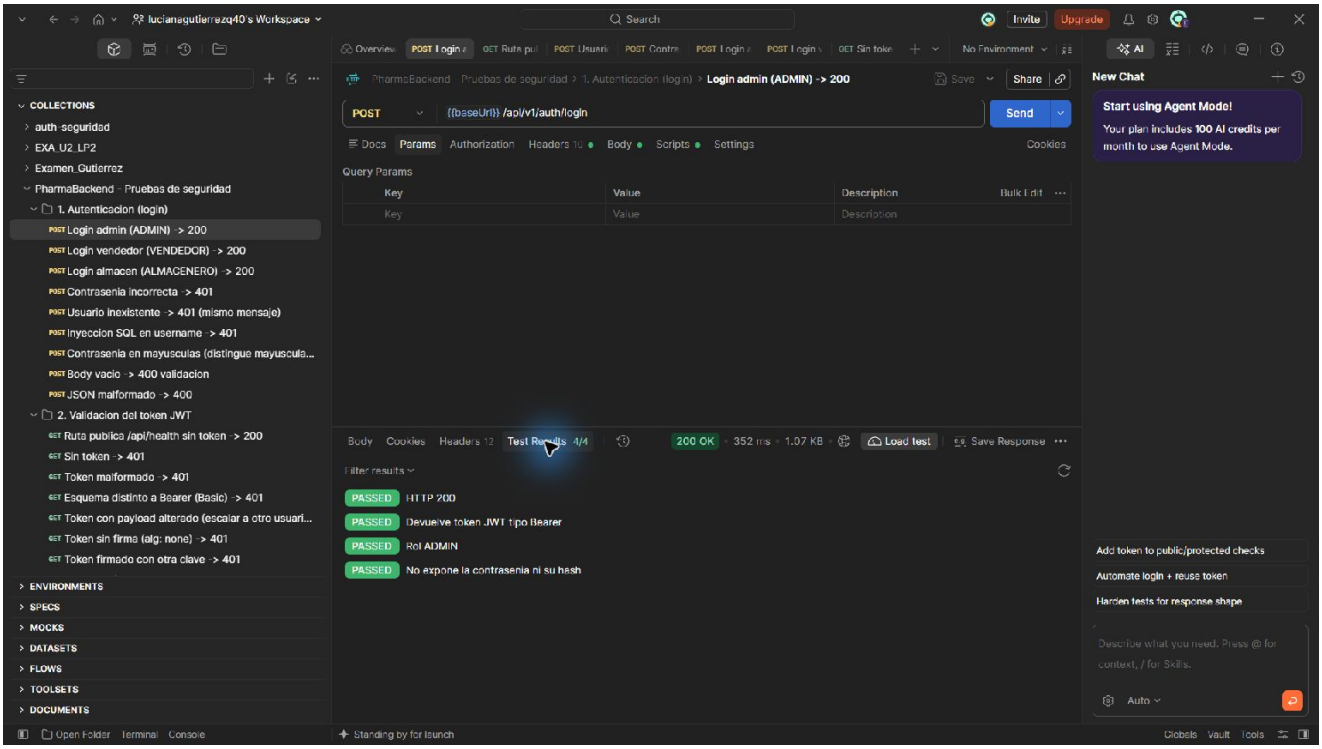
GET /api/v1/auth/me sin autenticación devuelve 401 Unauthorized: Debe iniciar sesión para acceder a este recurso.



Fuente: captura real de Android o Postman. Archivo: 14_postman_sin_token_401.jpg

Evidencia 12. Postman: autenticación ADMIN

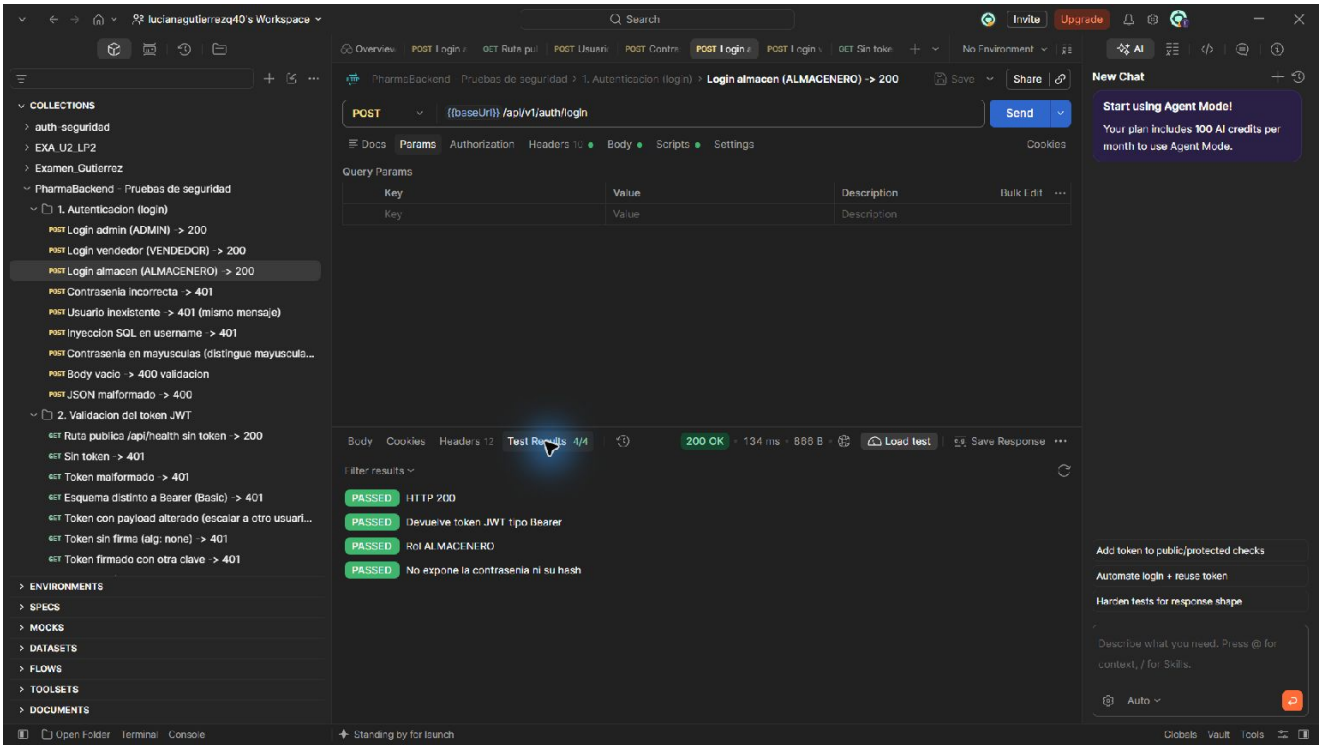
La respuesta es 200 OK. Las cuatro pruebas pasan: estado HTTP, token Bearer, rol ADMIN y ausencia de contraseña/hash en la respuesta. Se muestra Test Results para evitar publicar el JWT.



Fuente: captura real de Android o Postman. Archivo: 15_postman_admin_200.jpg

Evidencia 13. Postman: autenticación ALMACENERO

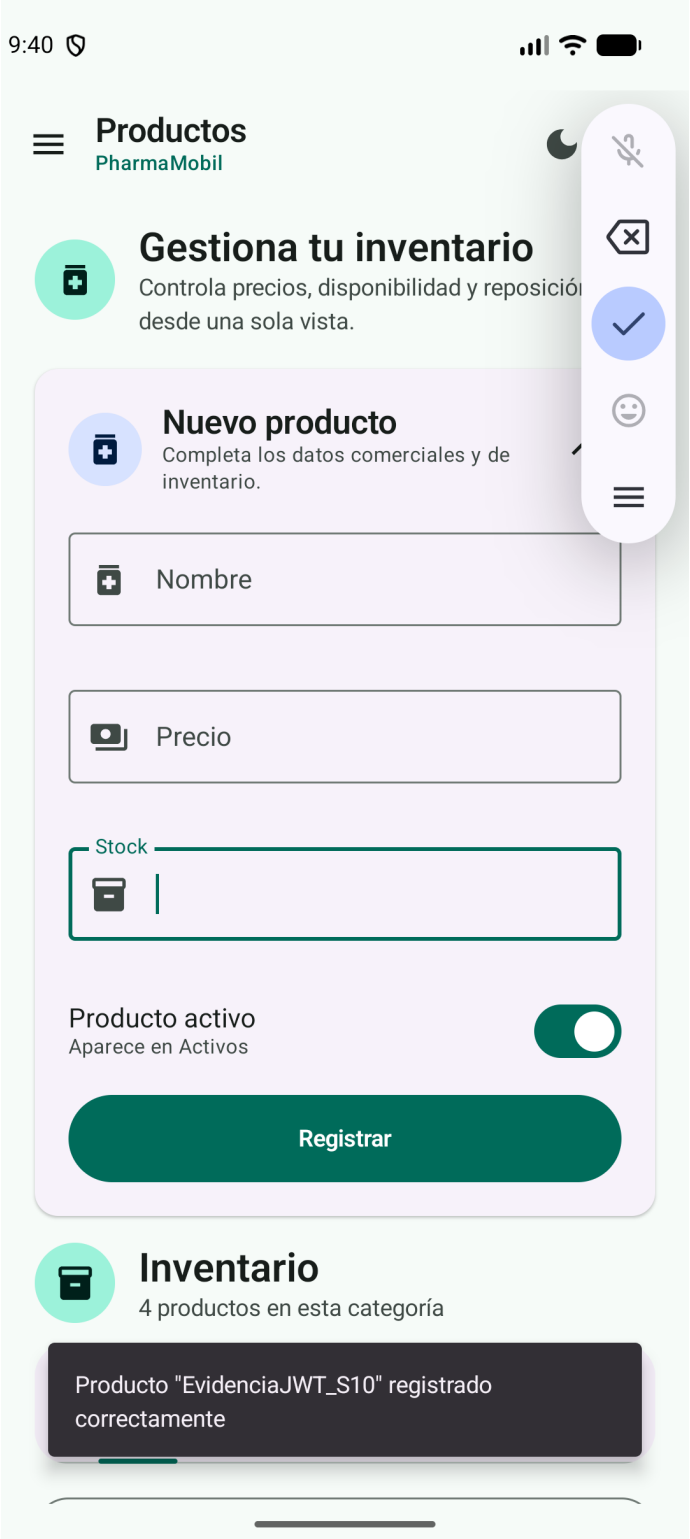
La respuesta es 200 OK y las cuatro pruebas pasan, incluido el rol ALMACENERO. La captura no expone el token ni las credenciales.



Fuente: captura real de Android o Postman. Archivo: 16_postman_almacen_200.jpg

Evidencia 14. CRUD Android: creación autenticada

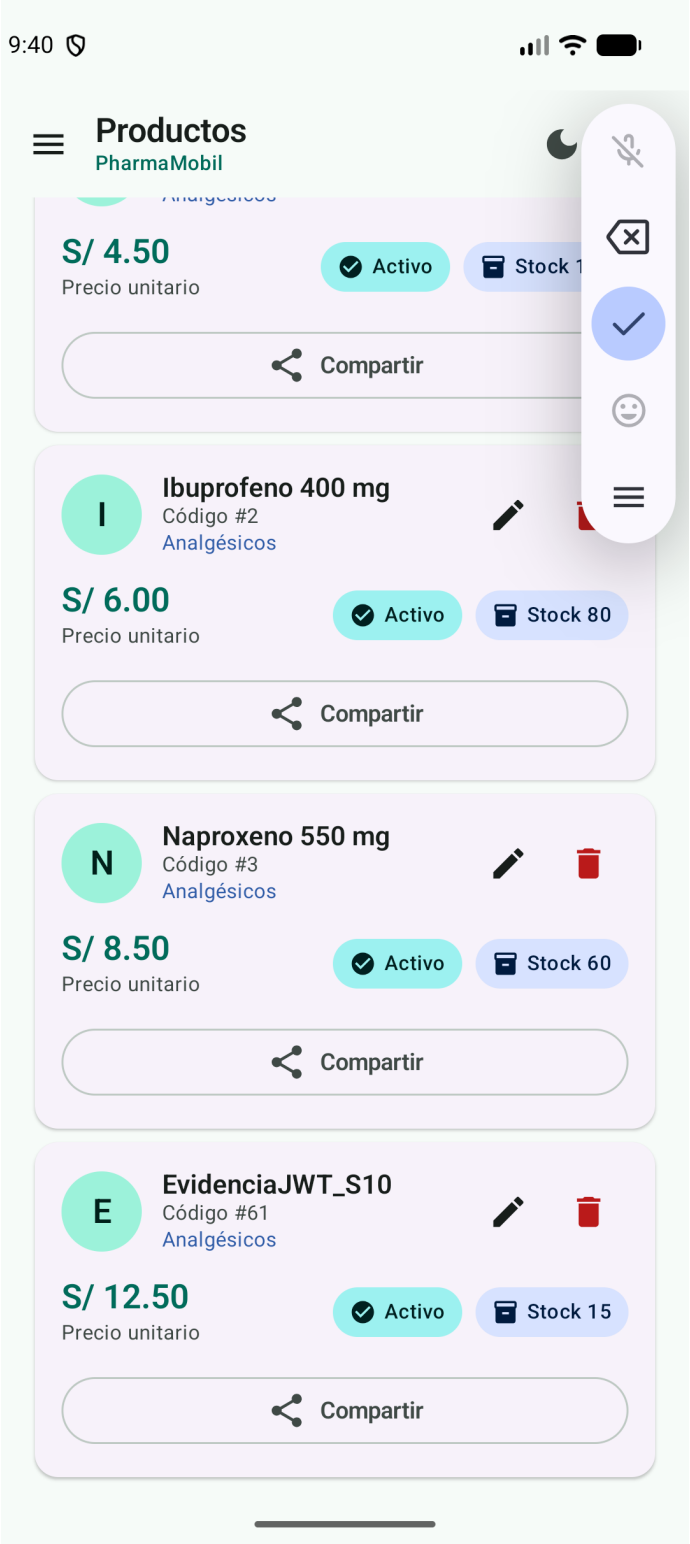
POST productos devuelve HTTP 201 y la app confirma el registro de EvidenciaJWT_S10, id 61, con precio 12.50 y stock 15. Se utilizó únicamente un producto nuevo de prueba.



Fuente: captura real de Android o Postman. Archivo: 19_crud_creado.png

Evidencia 15. CRUD Android: lectura autenticada

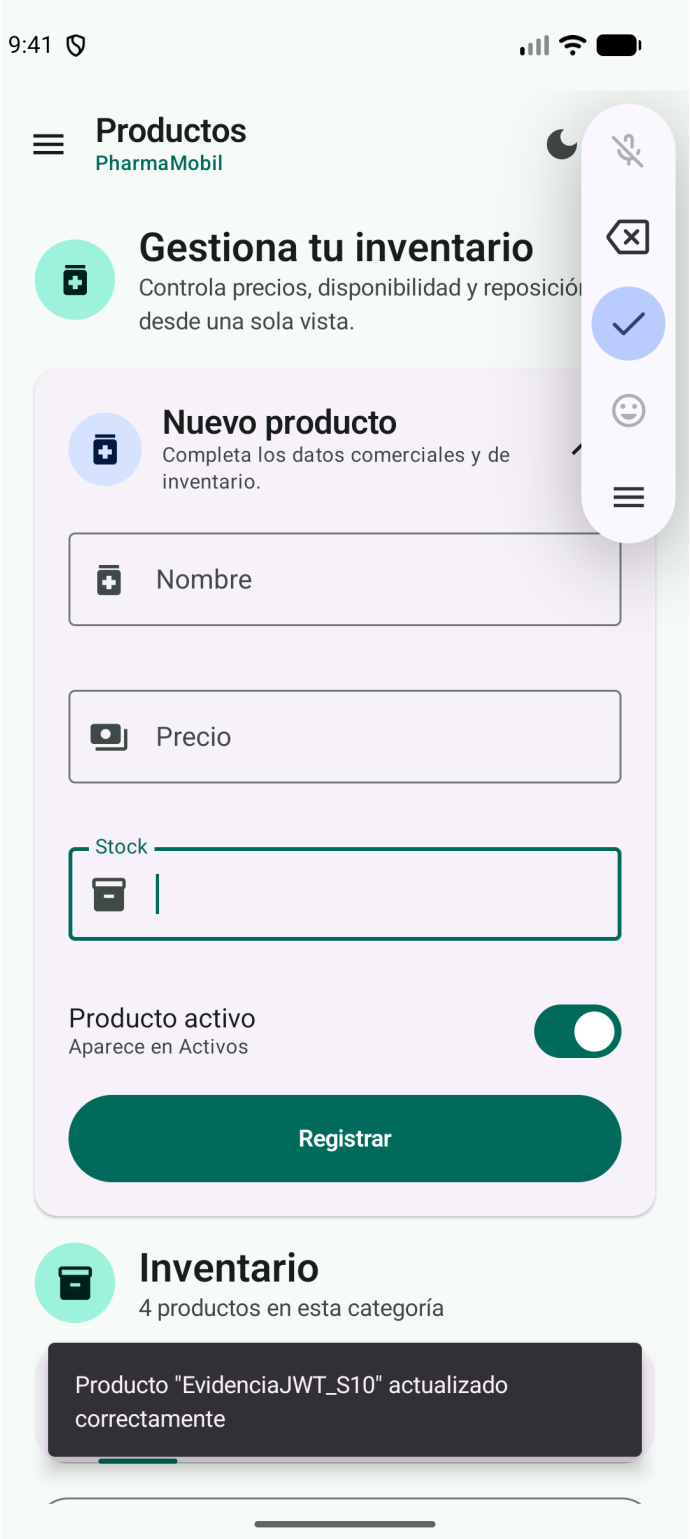
El catálogo remoto muestra el producto EvidenciaJWT_S10 después de la creación. La consulta GET protegida respondió HTTP 200.



Fuente: captura real de Android o Postman. Archivo: 20_crud_listado.png

Evidencia 16. CRUD Android: actualización autenticada

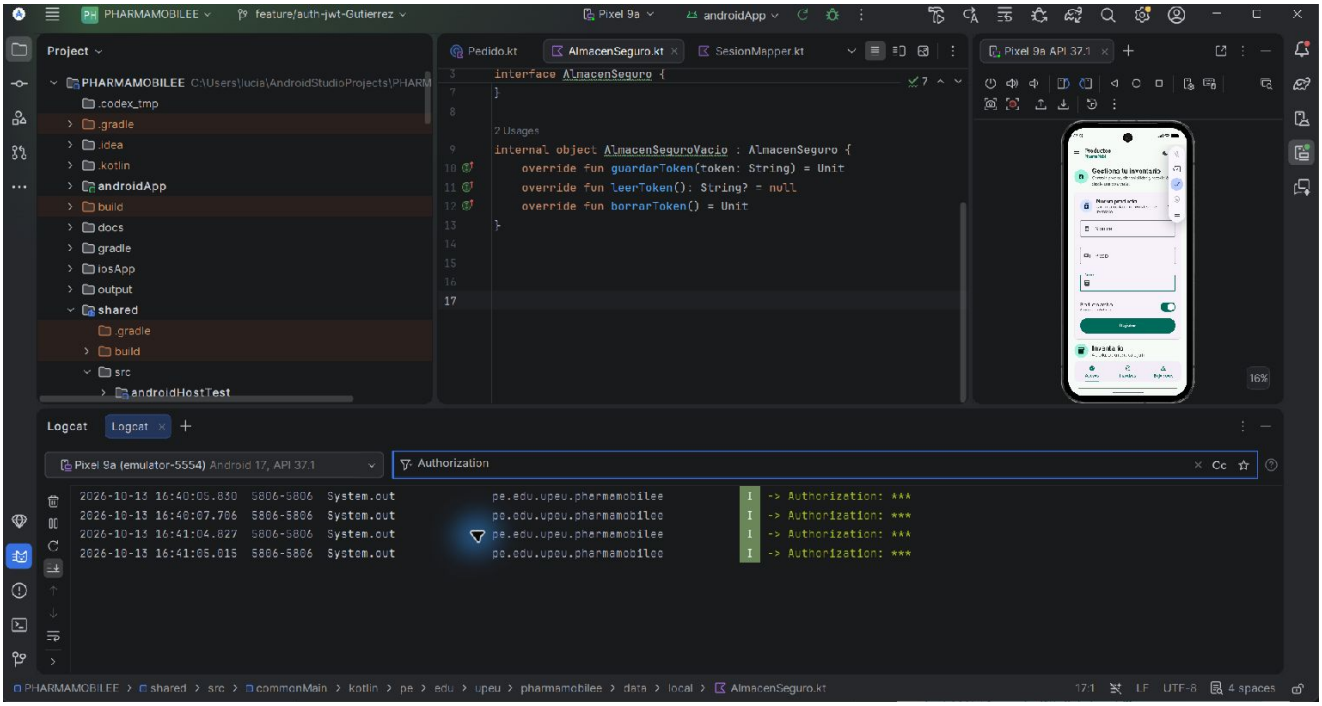
PUT productos/61 respondió HTTP 200. El precio cambió a 14 y el stock a 18; Android mostró actualizado correctamente.



Fuente: captura real de Android o Postman. Archivo: 21_crud_actualizado.png

Evidencia 17. Registro de Authorization saneado

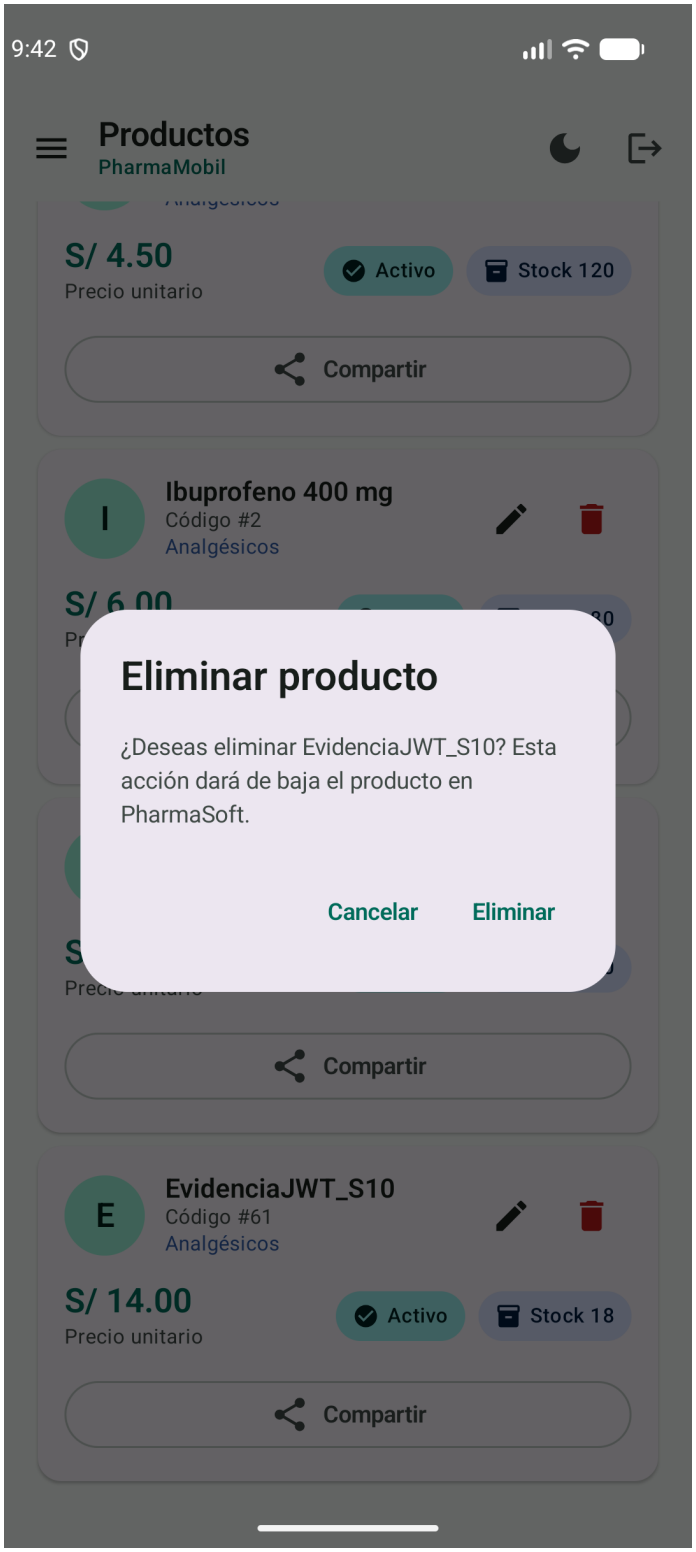
Android Studio muestra el registro real del emulador con Authorization: ***. El JWT completo no aparece en el log. El registro está habilitado solo para depuración.



Fuente: captura real de Android o Postman. Archivo: 22_logcat_saneado.jpg

Evidencia 18. CRUD Android: confirmación de baja lógica

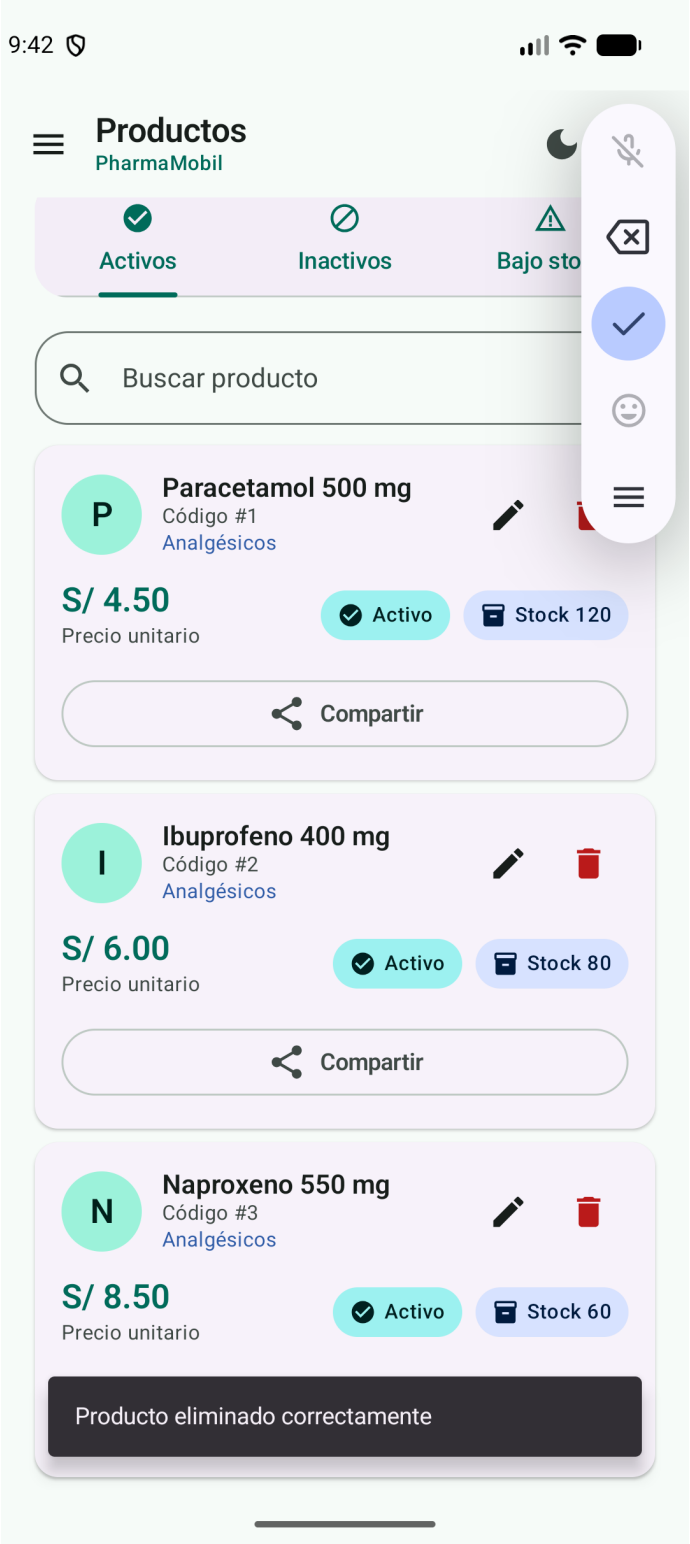
El diálogo identifica expresamente el producto de prueba EvidenciaJWT_S10. No se seleccionó ninguno de los productos anteriores.



Fuente: captura real de Android o Postman. Archivo: 23_crud_eliminado.png

Evidencia 19. CRUD Android: eliminación autenticada

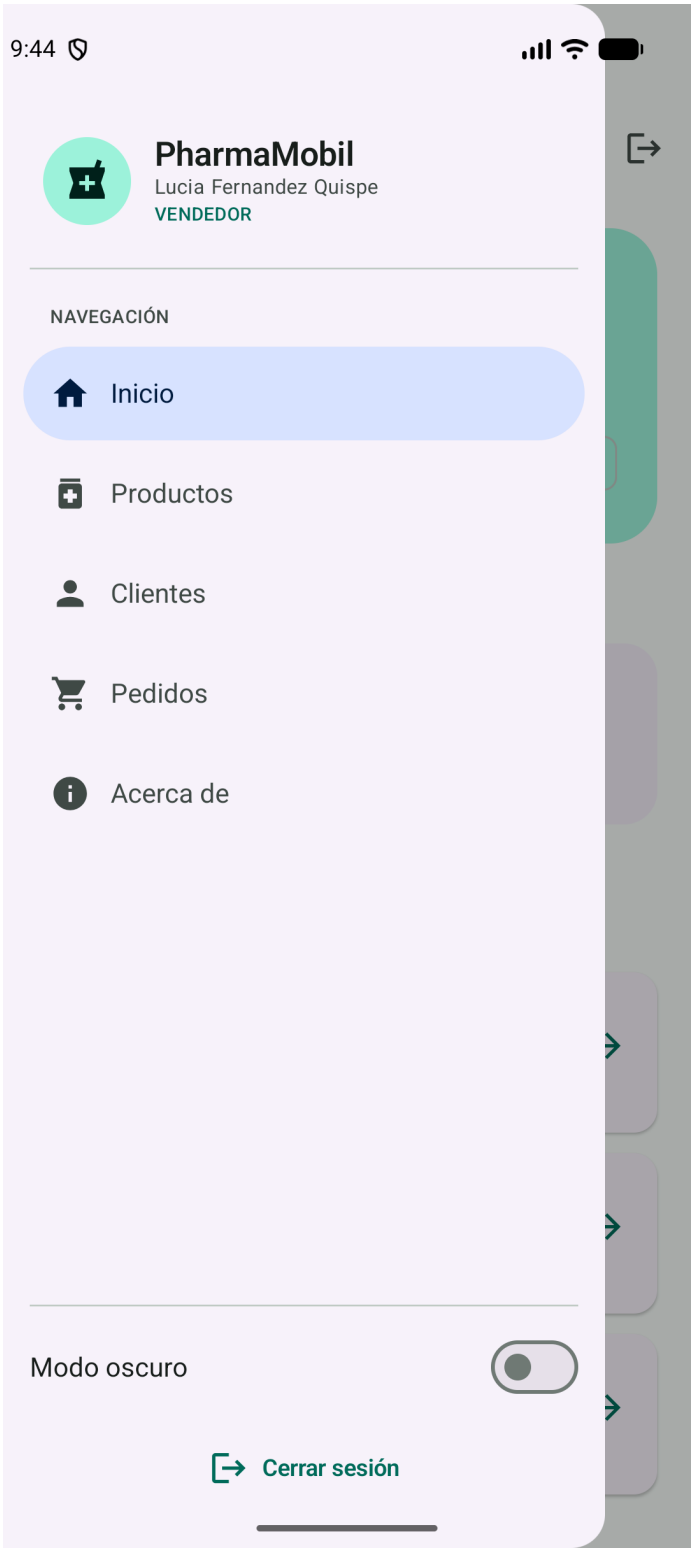
DELETE productos/61 respondió HTTP 204. Android mostró Producto eliminado correctamente; Oracle confirmó estado FALSE. Se conserva el registro por borrado lógico.



Fuente: captura real de Android o Postman. Archivo: 24_crud_delete_ok.png

Evidencia 20. Login real del tercer usuario VENDEDOR

PharmaSoft autenticó vendedor y Compose muestra VENDEDOR, Productos, Clientes y Pedidos según sus permisos.



Fuente: captura real de Android o Postman. Archivo: 25_menu_vendedor.png

Evidencia 21. VENDEDOR: catálogo sin escritura

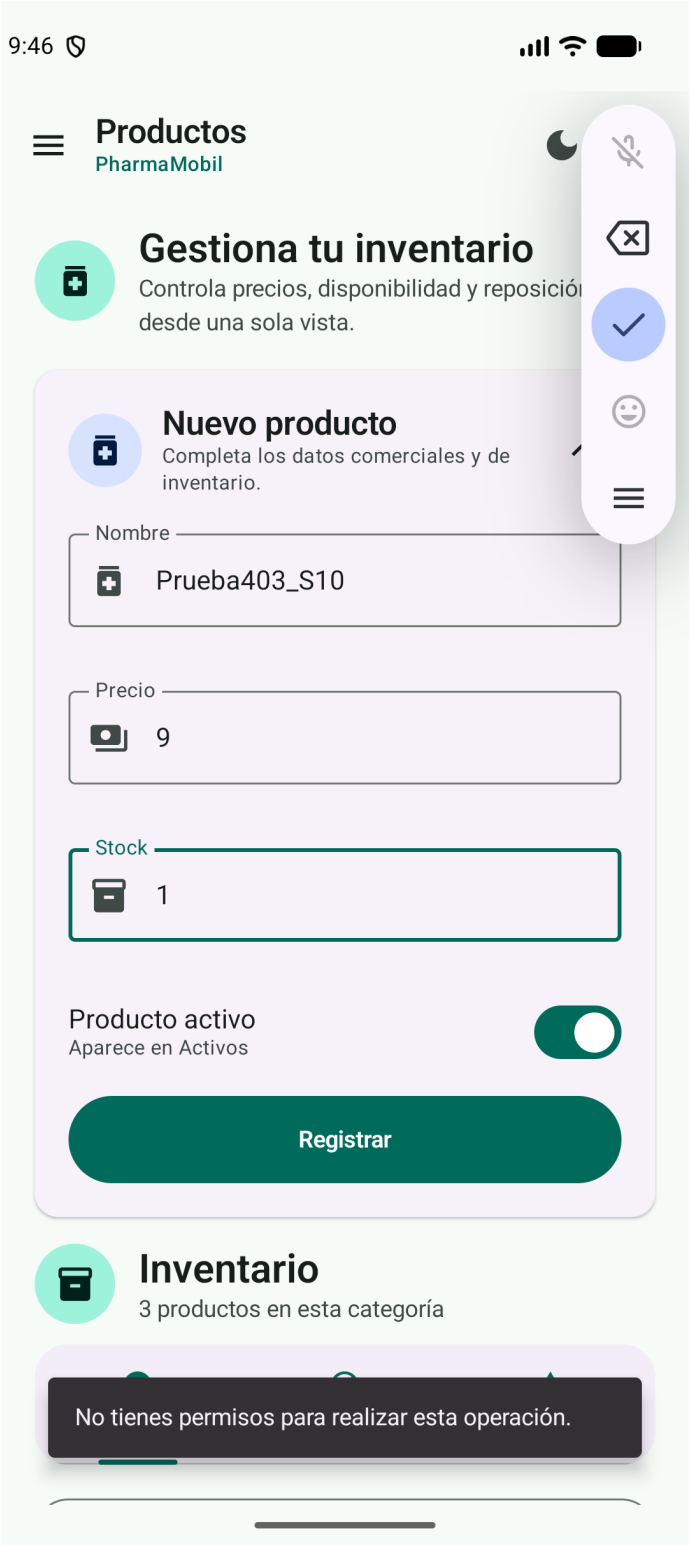
La UI mantiene la lectura del inventario, pero no muestra el formulario Nuevo producto ni los controles de editar o eliminar.



Fuente: captura real de Android o Postman. Archivo: 26_vendedor_sin_escritura.png

Evidencia 22. 403 deliberado y sesión conservada

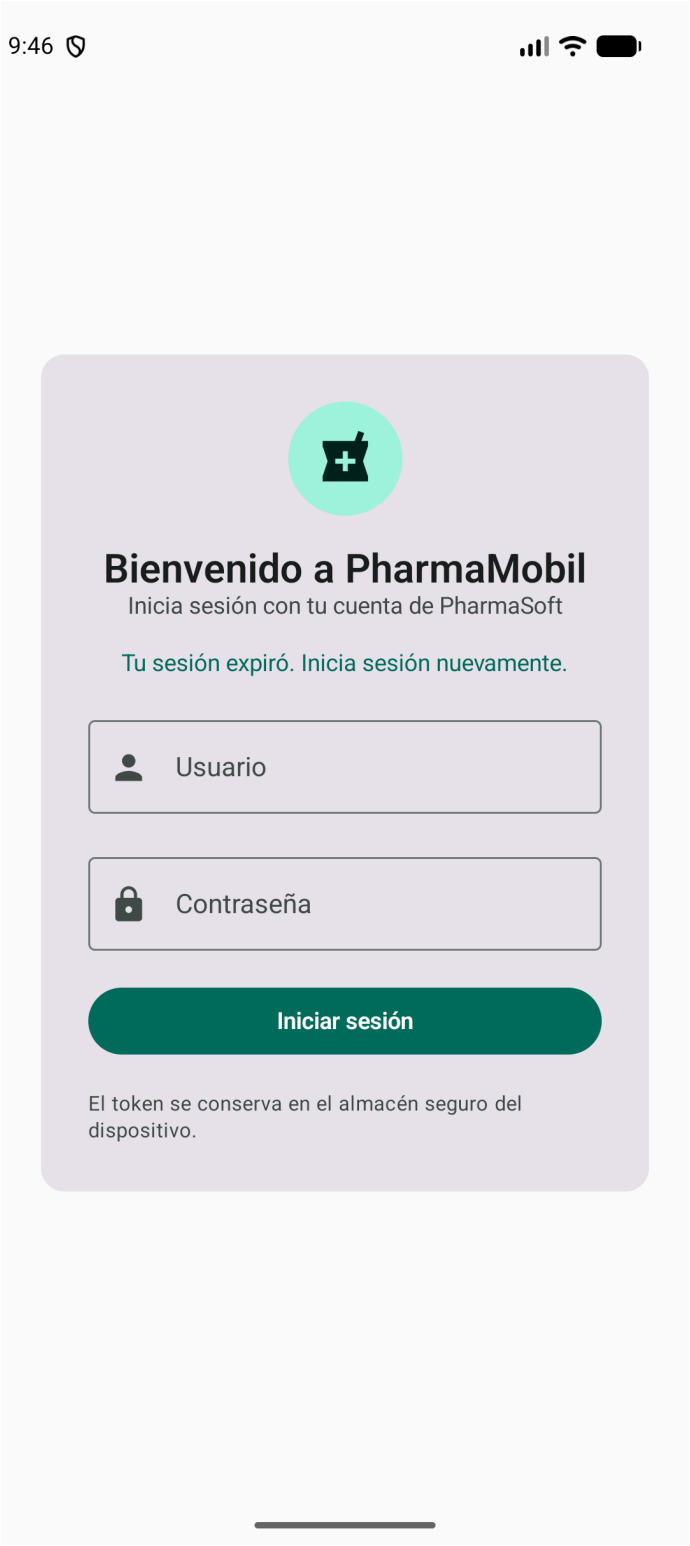
Se revocó temporalmente la escritura de la cuenta local almacen después de abrir la sesión. El POST recibió 403 y Android mostró No tienes permisos para realizar esta operación. Productos permaneció abierto. El rol ALMACENERO se restauró inmediatamente en finally.



Fuente: captura real de Android o Postman. Archivo: 27_android_403.png

Evidencia 23. 401 real y regreso al login

Se deshabilitó temporalmente la cuenta local de prueba. El backend devolvió 401; Android borró el token y volvió al login con Tu sesión expiró. Inicia sesión nuevamente. La cuenta se restauró a estado TRUE. Es una prueba de revocación, no una espera de expiración temporal.



Fuente: captura real de Android o Postman. Archivo: 28_android_401_login.png